Acme Corp IT Security Policy 2026

Version 4.0 — Effective 1 January 2026 — Owner: Chief Information Security Officer

1. Purpose and Scope

This policy defines the minimum security controls for all Acme Corp information systems, applications, and users. It applies to employees, contractors, and third parties accessing Acme Corp systems from any device or location.

This policy is effective from 1 January 2026 and is reviewed annually by the Information Security Committee. Exceptions require written approval from the Chief Information Security Officer (CISO) and expire automatically after 90 days unless renewed.

2. Password and Authentication Policy

All corporate and cloud application accounts must satisfy the following minimum requirements:

Requirement	Minimum standard
Password length	12 characters minimum
Complexity	At least one uppercase, one lowercase, one digit, one special character
Rotation	Every 180 days; immediate change on suspicion of compromise
History	Last 10 passwords cannot be reused
Account lockout	After 5 failed attempts, locked for 15 minutes
Password manager	Mandatory for all corporate credentials; provided by IT

Multi-factor authentication (MFA) is mandatory for all cloud applications, remote VPN access, and administrator accounts, using the approved authenticator app; SMS-based MFA is not permitted for Restricted systems.

Credentials must never be shared, embedded in code, or stored outside the corporate password manager. Any suspected credential exposure must be reported within 24 hours and triggers a forced reset.

3. Device Security

Full-disk encryption (FileVault or BitLocker) is mandatory on all laptops and mobile devices used for Acme Corp work, including personal devices under the BYOD programme.

Devices must auto-lock after 5 minutes of inactivity with a password or biometric unlock. Critical OS and browser patches must be applied within 72 hours of release; all other security patches within 14 days.

Loss or theft of any device with access to corporate systems must be reported to security@acme.example and the IT helpdesk within 24 hours; the device is remotely wiped and all stored sessions revoked.

Personal devices may access Internal-classification resources only through the managed browser; Confidential and Restricted resources require a corporate device.

4. Data Classification

All data must be classified at creation into one of four levels:

Level	Definition	Examples	Handling rule
Public	Approved for public release	Marketing material, job postings	No restriction
Internal	Default for business data	This policy, org charts	Employees and approved contractors
Confidential	Damage to Acme Corp if disclosed	Contracts, financials, HR records	Need-to-know; encrypted sharing
Restricted	Severe legal/financial harm if disclosed	Customer PII, health records, credentials	Named-access only; secure-share portal

Personally identifiable information (PII) of employees and customers is Restricted by default. Restricted data must be encrypted at rest and in transit, and shared only through the approved secure-share portal — never as email attachments.

Public disclosures of any data require sign-off from Corporate Communications and, for financial data, the CFO.

5. Incident Response and SLAs

Security incidents must be reported to security@acme.example immediately upon suspicion. The on-call security engineer triages every report against the following severity matrix and response targets:

Severity	Definition	Acknowledge within	Resolve within
Sev1	Critical: production down or confirmed data breach	15 minutes	4 hours
Sev2	High: major function degraded, limited breach risk	30 minutes	8 hours
Sev3	Medium: single-system issue, workaround exists	4 hours	3 business days
Sev4	Low: query or cosmetic defect	1 business day	10 business days

A suspected breach of personal data must additionally be notified to the Data Protection Officer within 24 hours for statutory assessment, and to affected customers per contractual terms.

Every Sev1 and Sev2 incident requires a blameless post-incident review within 5 business days, with tracked corrective actions owned by the responsible engineering lead.

6. Access Control

Access follows least privilege and role-based access control. Access requests are raised in the identity portal, approved by the system owner, and granted within 2 business days for standard roles.

Access rights are reviewed quarterly by system owners; unused accounts are disabled after 45 days of inactivity and deleted after 90 days.

Leavers lose all access on their last working day (same-day revocation by IT upon HR trigger). Privileged (administrator) access requires a named individual, a justification, and automatic expiry after 90 days.

7. Third-Party and Cloud Security

Every vendor handling Acme Corp data must pass a security assessment before onboarding and annually thereafter, and must sign the standard Data Processing Agreement (DPA).

Production data must never be copied into development or test environments; masked or synthetic data sets are provided by the data platform team on request.

Cloud workloads must run in approved accounts with mandatory logging, and internet-exposed services require a security review plus CISO-approved exception register entry.